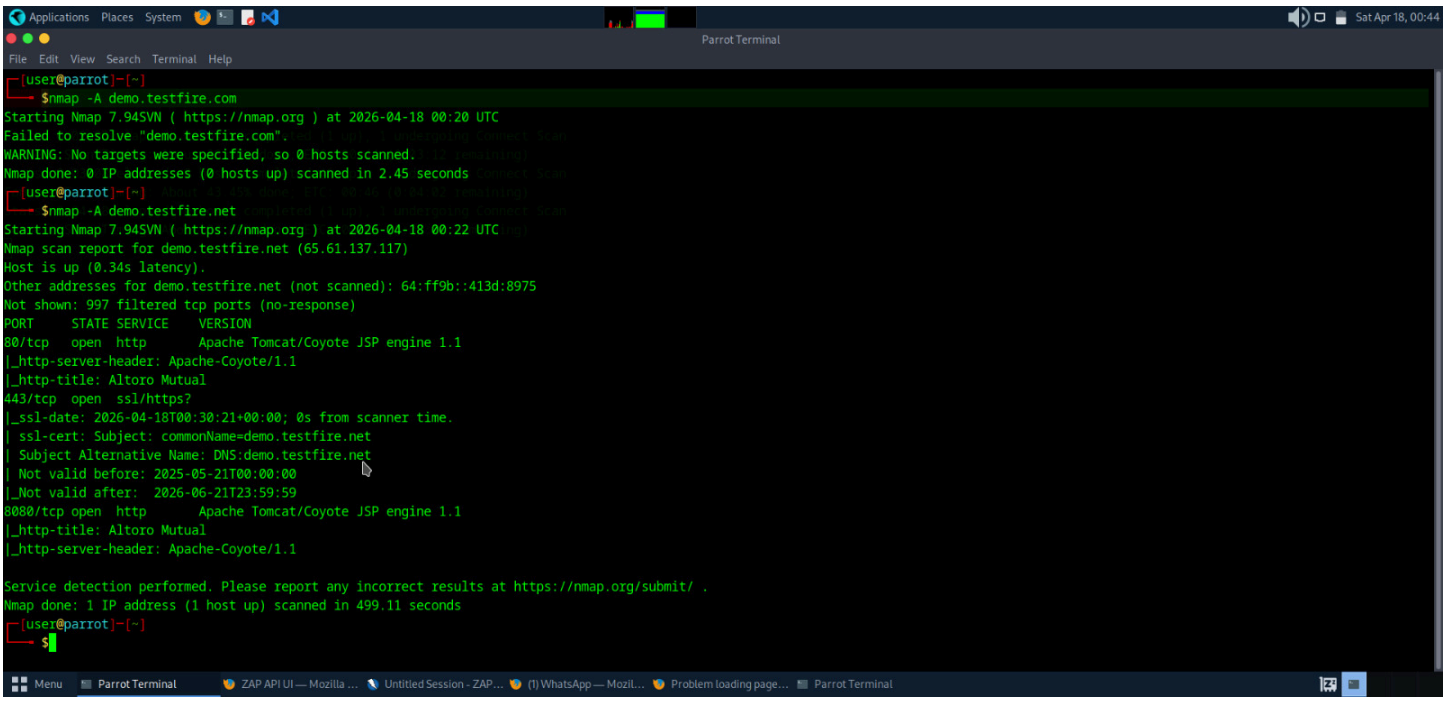
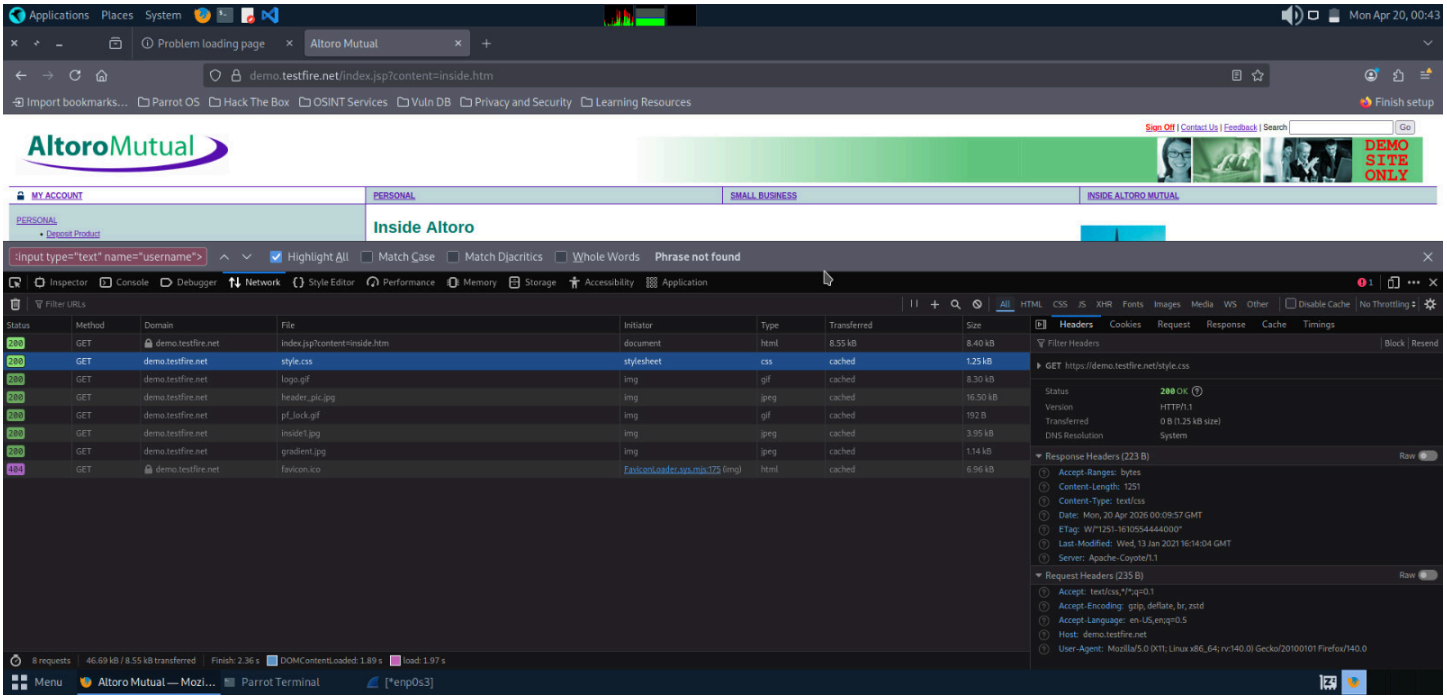
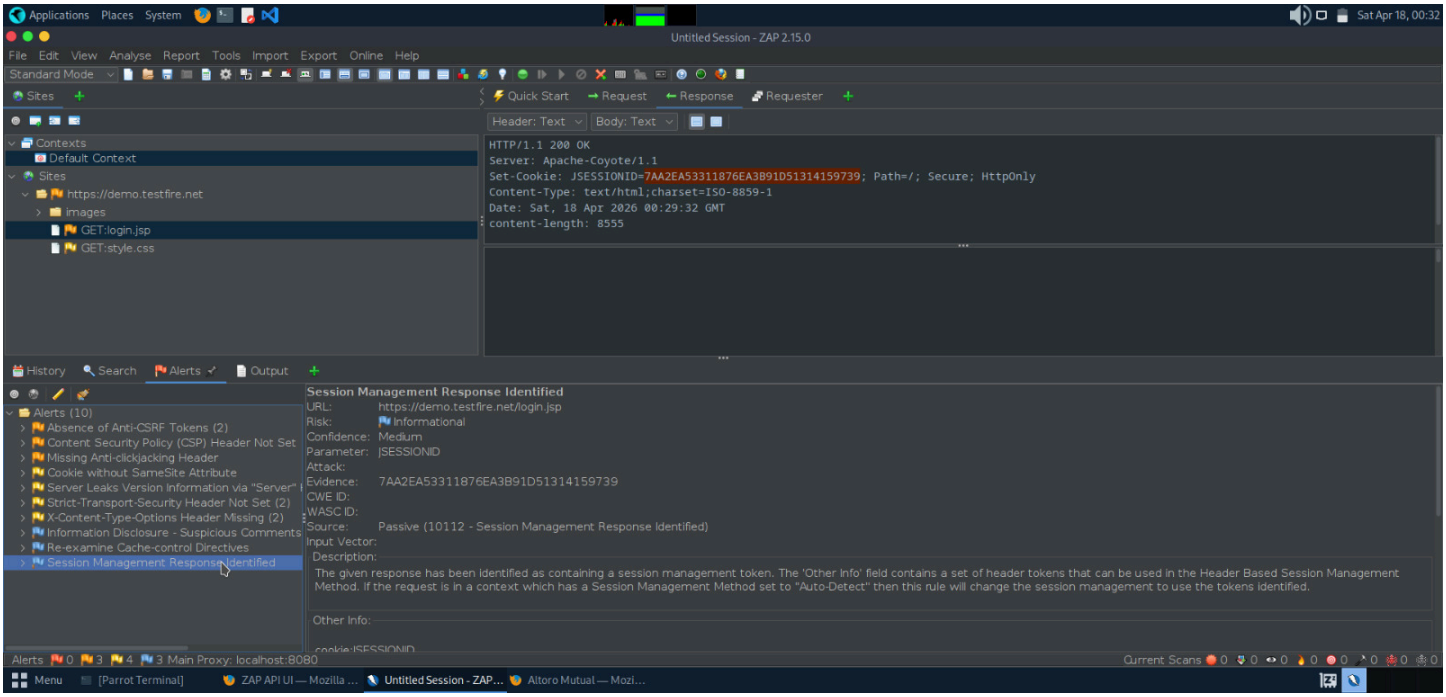
1.Nmap

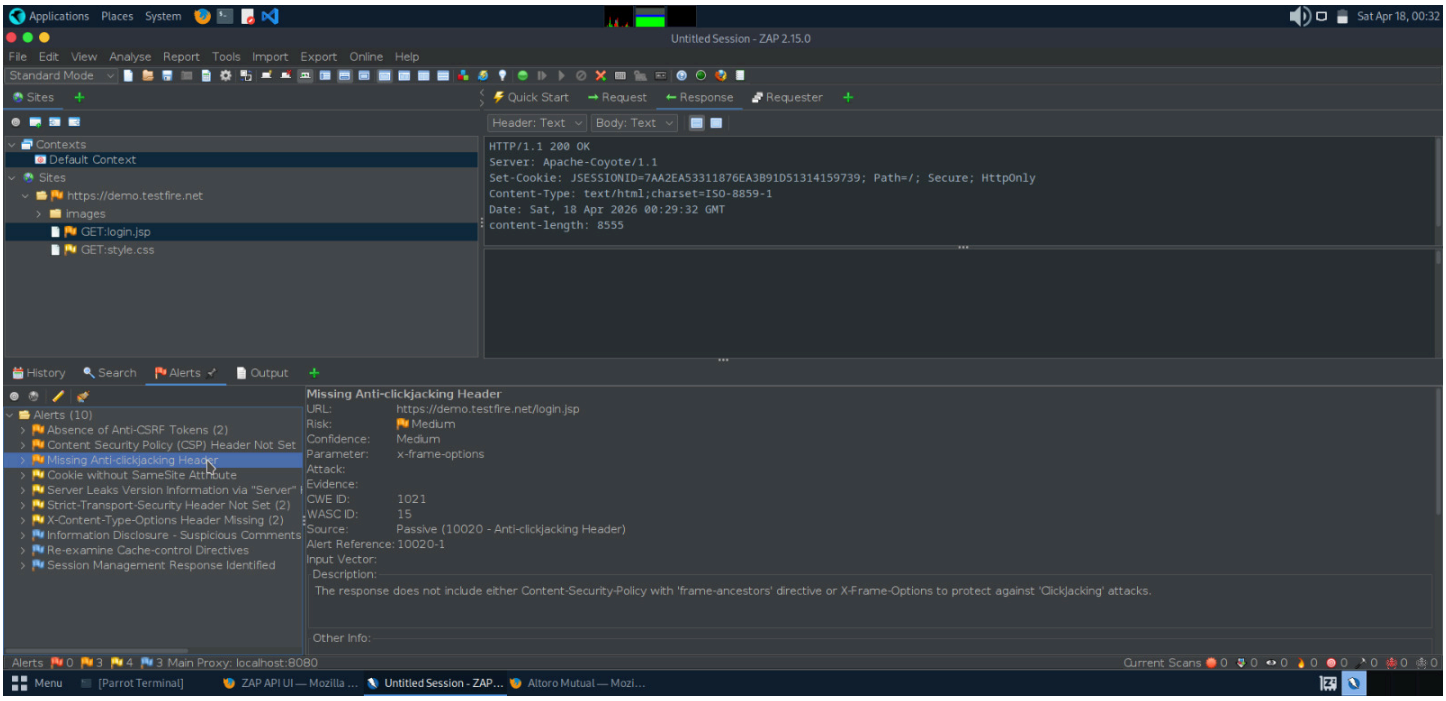


2.Dev Tool



3.owasp tool


Untitled Session - ZAP 2.15.0
File Edit View Analyse Report Tools Import Export Online Help
Sites
Quick Start
Request
Response
Requester
Contexts
Default Context
https://demo.testfire.net
images
GET:login.jsp
GET:style.css
HTTP/1.1 200 OK
Server: Apache-Coyote/1.1
Set-Cookie: JSESSIONID=7AA2EA53311876EA3B91D51314159739; Path=/; Secure; HttpOnly
Content-Type: text/html;charset=ISO-8859-1
Date: Sat, 18 Apr 2026 00:29:32 GMT
content-length: 8555
History
Search
Alerts
Output
Alerts (10)
Absence of Anti-CSRF Tokens (2)
Content Security Policy (CSP) Header Not Set
Missing Anti-clickjacking Header
Cookie without SameSite Attribute
Server Leaks Version Information via "Server"
Strict-Transport-Security Header Not Set (2)
X-Content-Type-Options Header Missing (2)
Information Disclosure - Suspicious Comments
Re-examine Cache-control Directives
Session Management Response Identified
Session Management Response Identified
URL: https://demo.testfire.net/login.jsp
Risk: Informational
Confidence: Medium
Parameter: JSESSIONID
Attack:
Evidence: 7AA2EA53311876EA3B91D51314159739
CWE ID:
WASC ID:
Source: Passive (10112 - Session Management Response Identified)
Input Vector:
Description:
The given response has been identified as containing a session management token. The 'Other Info' field contains a set of header tokens that can be used in the Header Based Session Management Method. If the request is in a context which has a Session Management Method set to "Auto-Detect" then this rule will change the session management to use the tokens identified.
Other Info:


Untitled Session - ZAP 2.15.0
File Edit View Analyse Report Tools Import Export Online Help
Sites
Quick Start
Request
Response
Requester
Contexts
Default Context
https://demo.testfire.net
images
GET:login.jsp
GET:style.css
HTTP/1.1 200 OK
Server: Apache-Coyote/1.1
Set-Cookie: JSESSIONID=7AA2EA53311876EA3B91D51314159739; Path=/; Secure; HttpOnly
Content-Type: text/html;charset=ISO-8859-1
Date: Sat, 18 Apr 2026 00:29:32 GMT
content-length: 8555
History
Search
Alerts
Output
Alerts (10)
Absence of Anti-CSRF Tokens (2)
Content Security Policy (CSP) Header Not Set
Missing Anti-clickjacking Header
Cookie without SameSite Attribute
Server Leaks Version Information via "Server"
Strict-Transport-Security Header Not Set (2)
X-Content-Type-Options Header Missing (2)
Information Disclosure - Suspicious Comments
Re-examine Cache-control Directives
Session Management Response Identified
Missing Anti-clickjacking Header
URL: https://demo.testfire.net/login.jsp
Risk: Medium
Confidence: Medium
Parameter: x-frame-options
Attack:
Evidence:
CWE ID: 1021
WASC ID: 15
Source: Passive (10020 - Anti-clickjacking Header)
Alert Reference: 10020-1
Input Vector:
Description:
The response does not include either Content-Security-Policy with 'frame-ancestors' directive or X-Frame-Options to protect against 'Clickjacking' attacks.
Other Info:

Applications Places System Sat Apr 18, 00:32

Untitled Session - ZAP 2.15.0

File Edit View Analyse Report Tools Import Export Online Help

Standard Mode

Sites

Contexts
- Default Context

Sites
- https://demo.testfire.net
  - images
  - GET:login.jsp
  - GET:style.css

Quick Start | Request | Response | Requester

Header: Text | Body: Text

```
HTTP/1.1 200 OK
Server: Apache-Coyote/1.1
Set-Cookie: JSESSIONID=7AA2EA53311876EA3B91D51314159739; Path=/; Secure; HttpOnly
Content-Type: text/html;charset=ISO-8859-1
Date: Sat, 18 Apr 2026 00:29:32 GMT
content-length: 8555
```

History | Search | Alerts | Output

Alerts (10)
- Absence of Anti-CSRF Tokens (2)
- Content Security Policy (CSP) Header Not Set
- Missing Anti-clickjacking Header
- Cookie without SameSite Attribute
- Server Leaks Version Information via "Server"
- Strict-Transport-Security Header Not Set (2)
- X-Content-Type-Options Header Missing (2)
- Information Disclosure - Suspicious Comments
- Re-examine Cache-control Directives
- Session Management Response Identified

Content Security Policy (CSP) Header Not Set

URL: https://demo.testfire.net/login.jsp
Risk: Medium
Confidence: High
Parameter:
Attack:
Evidence:
CWE ID: 693
WASC ID: 15
Source: Passive (10038 - Content Security Policy (CSP) Header Not Set)
Alert Reference: 10038-1
Input Vector:

Description:

Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.

Other Info:

Alerts 0 3 4 3 Main Proxy: localhost:8080 Current Scans 0 0 0 0 0 0 0 0

Menu [Parrot Terminal] ZAP API UI — Mozilla ... Untitled Session - ZAP... Altoro Mutual — Mozi...

Applications Places System Sat Apr 18, 00:32

Untitled Session - ZAP 2.15.0

File Edit View Analyse Report Tools Import Export Online Help

Standard Mode

Sites | Quick Start | Request | Response | Requester

Header: Text | Body: Text

Contexts
- Default Context

Sites
- https://demo.testfire.net
  - images
  - GET:login.jsp
  - GET:style.css

```
HTTP/1.1 200 OK
Server: Apache-Coyote/1.1
Set-Cookie: JSESSIONID=7AA2EA53311876EA3B91D51314159739; Path=/; Secure; HttpOnly
Content-Type: text/html;charset=ISO-8859-1
Date: Sat, 18 Apr 2026 00:29:32 GMT
content-length: 8555
```

```
<td valign="top" colspan="3" class="bb">
        <div class="fl" style="width: 99%;">

        <h1>Online Banking Login</h1>

        <!-- To get the latest admin login, please contact SiteOps at 415-555-6159 -->
```

History | Search | Alerts | Output

Alerts (10)
- Absence of Anti-CSRF Tokens (2)
- Content Security Policy (CSP) Header Not Set
- Missing Anti-clickjacking Header
- Cookie without SameSite Attribute
- Server Leaks Version Information via "Server"
- Strict-Transport-Security Header Not Set (2)
- X-Content-Type-Options Header Missing (2)
- Information Disclosure - Suspicious Comments
- Re-examine Cache-control Directives
- Session Management Response Identified

Information Disclosure - Suspicious Comments

URL: https://demo.testfire.net/login.jsp
Risk: Informational
Confidence: Medium
Parameter:
Attack:
Evidence: admin
CWE ID: 200
WASC ID: 13
Source: Passive (10027 - Information Disclosure - Suspicious Comments)
Input Vector:

Description:
The response appears to contain suspicious comments which may help an attacker. Note: Matches made within script blocks or files are against the entire content not only comments.

Other Info:
The following pattern was used: \bADMIN\b and was detected in the element starting with: "<!-- To get the latest admin login, please contact SiteOps at 415-555-6159 -->", see evidence field for the suspicious comment/snippet.

Alerts 0 3 4 3 Main Proxy: localhost:8080 Current Scans 0 0 0 0 0 0 0 0 0

Menu [Parrot Terminal] ZAP API UI — Mozilla ... Untitled Session - ZAP... Altoro Mutual — Mozi...

Applications Places System Sat Apr 18, 00:32

Untitled Session - ZAP 2.15.0

File Edit View Analyse Report Tools Import Export Online Help

Standard Mode

Sites | Quick Start | Request | Response | Requester

Header: Text | Body: Text

Contexts
- Default Context

Sites
- https://demo.testfire.net
  - images
  - GET:login.jsp
  - GET:style.css

```
HTTP/1.1 200 OK
Server: Apache-Coyote/1.1
Set-Cookie: JSESSIONID=7AA2EA53311876EA3B91D51314159739; Path=/; Secure; HttpOnly
Content-Type: text/html;charset=ISO-8859-1
Date: Sat, 18 Apr 2026 00:29:32 GMT
content-length: 8555
```

```
<td valign="top" colspan="3" class="bb">
        <div class="fl" style="width: 99%;">

        <h1>Online Banking Login</h1>

        <!-- To get the latest admin login, please contact SiteOps at 415-555-6159 -->
```

History | Search | Alerts | Output

Alerts (10)
- Absence of Anti-CSRF Tokens (2)
- Content Security Policy (CSP) Header Not Set
- Missing Anti-clickjacking Header
- Cookie without SameSite Attribute
- Server Leaks Version Information via "Server"
- Strict-Transport-Security Header Not Set (2)
- X-Content-Type-Options Header Missing (2)
- Information Disclosure - Suspicious Comments
- Re-examine Cache-control Directives
- Session Management Response Identified

Information Disclosure - Suspicious Comments

URL: https://demo.testfire.net/login.jsp
Risk: Informational
Confidence: Medium
Parameter:
Attack:
Evidence: admin
CWE ID: 200
WASC ID: 13
Source: Passive (10027 - Information Disclosure - Suspicious Comments)
Input Vector:

Description:
The response appears to contain suspicious comments which may help an attacker. Note: Matches made within script blocks or files are against the entire content not only comments.

Other Info:
The following pattern was used: \bADMIN\b and was detected in the element starting with: "<!-- To get the latest admin login, please contact SiteOps at 415-555-6159 -->", see evidence field for the suspicious comment/snippet.

Alerts 0 3 4 3 Main Proxy: localhost:8080 Current Scans 0 0 0 0 0 0 0 0 0

Menu [Parrot Terminal] ZAP API UI — Mozilla ... Untitled Session - ZAP... Altoro Mutual — Mozi...